Pagemark 1.0.0 gate audit

Version 0.13.0

Commit b1bbf51

2026-10-14

Release readiness - Pagemark 1.0.0 gate (audited 0.13.0, commit b1bbf51)

Verdict: READY WITH CONDITIONS. No blocker, critical or high finding. The code is in good shape for 1.0.0; the conditions are a few small fixes, the documentation set, and a real-phone pass nobody has done yet.

(The 0.7.0 verdict and its 84 findings are in `FINDINGS.md` above the 1.0.0 section; all were fixed in 0.7.1 to 0.8.1. Their READY FOR VERIFICATION status was not re-run one by one in this gate; the suite, migrations and release checks cover the same ground.)

Counts (new this round)

Severity	Count	IDs
BLOCKER / CRITICAL / HIGH	0	
MEDIUM	4	PGM-300, PGM-302, PGM-320, PGM-324
LOW	4	PGM-301, PGM-303, PGM-321, PGM-322
INFO	4	PGM-323 (accepted), PGM-325 to PGM-327 (verified positives)

Conditions for tagging 1.0.0

1. **Fix PGM-320** (stuck timer), **PGM-300** (Stats width on tablets), **PGM-302** (genre noise). These are the three a user would notice. PGM-301, 303, 321, 322 are small and should go in the same release.
2. **Documentation set (house rule for a major release):** regenerate User Manual, Install Manual, Release Notes and README, write the Package Overview (simple, medium, advanced) and refresh the GitHub details (PGM-324).
3. **Real-phone pass** from `MANUAL_TEST_PLAN.md`, in particular the timer, folder backup to a real cloud folder, fingerprint, notifications, TalkBack and the updater.
4. **Google Play steps** (account, 14-day closed test, Data safety form, listing) are outside the code. The Play bundle builds; see `docs/PLAY_STORE.md`.

Localisation is not a gate item; it needs a second language chosen first.

What was and was not tested

Phase	Result
Baseline, suite, generated code	pass, twice
Migrations schema 1 to 5 to 6	pass, all rows kept, integrity and foreign keys clean
Release assets	signature, hash, secrets, permissions, 16 KB alignment checked; CI green
Hostile input (new parsers)	fuzzed, only PGM-303
GUI	tablet rail, two panes, Stats, font 2.0 seen; full activation sweep NOT RUN
Data safety (backup, restore, folder)	unchanged since the 0.7.0 audit; real providers NOT RUN
Performance	NOT RUN this round
Real hardware, TalkBack, notifications, camera	NOT RUN

Top risks

- Anything that touches Android itself (folder picker, notifications, camera, share sheets, TalkBack) has only emulator or no coverage. The folder backup is the one with real data consequences.
- Lookup data quality: free sources return noisy genres and occasional wrong editions (PGM-302). Refresh details lets users fix it, but they must notice.
- The timer is the only new feature that holds state outside the database (PGM-320).

Build-session handoff

PGM-320 stuck timer. Repro: copy `scripts/pgm320_stuck_timer_test.dart` into `test/` and run it; it fails on the missing Stop. Cause: `lib/reading_life_ui.dart` `_other` blocks other books and the Stop button only shows for the timed book (`_mine`). Fix direction: when a timer belongs to another book, offer Stop (save or discard that session), and clear the saved timer when its book is finished, trashed or purged. Verify: the same test passes, plus a new test that finishing the book clears `timer_start`.

PGM-300 Stats width. Repro: emulator `wm size 2400x1440; wm density 280`, open Stats (`evidence_1.0/f12_stats.png`). Fix direction: wrap the Stats list in `NarrowColumn` and give the calendar grid a fixed cell height (`mainAxisExtent: 40`). Verify: same screenshot shows a one-screen month; add a widget test pumping Stats at 1200 dp asserting the grid is under 400 tall.

PGM-302 genre noise. Repro: search "dune frank herbert", add the first result, read the Genre line (`evidence_1.0/f11_pane_book.png`). Fix direction: in `Lookup.genres()` and Google categories, split subjects on commas, drop duplicates case-insensitively, drop "(imaginary place)" entries and the book's own title, keep three. Verify: a lookup_test with the Dune subject list returns clean genres.

PGM-301, 303, 321, 322: cap the guide and Add a book with `NarrowColumn`; reject `pages <= 0` or above 20,000 in `parseVolume` and `_parseDoc`; call `closeBook` after Move to locked library; give the empty-state button a book or help icon. Verify with the v0130 and pgm310 tests plus one widget test each.

1.0.0 gate audit (Pagemark 0.13.0, commit b1bbf51, 2026-10-14)

Rows PGM-300 to PGM-327 come from the gate audit. Counts: MEDIUM 4, LOW 4, INFO 4 (3 verified positives). No BLOCKER, CRITICAL or HIGH.

ID	Sev	Component	Finding	Evidence	Status
PGM-300	MEDIUM	Stats page (lib/features.dart Stats; calendar in reading_life_ui.dart StreakCard)	On screens 840 dp and wider the Stats page is not width-capped, so the month calendar's square day cells grow with the screen: at 1200 dp wide each cell is about 250 px tall and one month fills several screens. Landscape phones get the same, milder.	auditor (evidence_1.0/f12_stats.png)	OPEN
PGM-301	LOW	Guide, Add a book, Our promise and other pushed pages	Only the Settings sub-pages and Read next use NarrowColumn. The guide and Add a book are full width on a tablet (text lines about 1900 px long, search box edge to edge).	auditor (evidence_1.0/f4_tablet_land.png); code lib/ui/add_book.dart, lib/guide.dart	OPEN
PGM-302	MEDIUM	Lookup genre (lib/lookup.dart genres())	Open Library subjects are copied into Genre as-is: a lookup for Dune filled it with "Dune (Imaginary place), Fiction, science fiction, general, Dune (imaginary place), fiction" (duplicates, places, a subject that itself contains commas). Stats Top genres, the year card's favourite genre and the suggestions take the first comma-separated word, so they would report "Dune (Imaginary place)" as the genre.	auditor (evidence_1.0/f11_pane_book.png); code lib/features.dart:~470, lib/reading_life.dart yearSummary, lib/finding.dart suggestNext	OPEN
PGM-303	LOW	Lookup parsers (Google pageCount, Open Library number_of_pages_median)	A negative or absurd page count in a lookup answer is accepted and saved by Add (Refresh already rejects them), which would give negative or huge totals in Stats. 5,000 random shapes did not crash anything else.	script pgm310_lookup_fuzz_test.dart	OPEN
PGM-320	MEDIUM	ReadingTimerCard (lib/reading_life_ui.dart)	A running reading timer can be stranded: start it on book A, then finish or delete A. A's timer card disappears (it only shows on a read that is Reading) but the saved timer stays, and every other book shows "The reading timer is running for another book" with no Stop button. It is recoverable only by logging A as Reading again.	script pgm320_stuck_timer_test.dart (fails as expected)	OPEN
PGM-321	LOW	Two-pane book pane (lib/adaptive.dart, lib/ui/book_page.dart)	In the two-pane layout, choosing Move to locked library on the open book leaves that book showing in the main Library's right-hand pane (and it stays after switching tabs) until another book is chosen. Phone layout leaves the page open too but Back removes it.	code book_page.dart 'lock' handler (no closeBook), home.dart pane	OPEN
PGM-322	LOW	Empty library	"See how Pagemark works" carries a + icon like an Add button but opens the guide; the empty-state shows it beside the Add book button.	auditor (evidence_1.0/f2_after_skip.png)	OPEN
PGM-323	INFO	armeabi-v7a libbarhopper_v3.so (ML Kit)	Its ELF segments are 4 KB aligned. 32-bit libraries are exempt from the 16 KB rule; all 64-bit libraries are 16 KB aligned.	script pgm200_apk_scan.py	ACCEPTED RISK
PGM-324	MEDIUM	README.md, docs/release-package/*, docs/UI_LAYOUT.md	README names only Open Library and GitHub as network use and lists none of the 0.10 to 0.13 features. The User Manual, Install Manual, Release Notes and Package Overview are versions 0.7.0 to 0.8.0; UI_LAYOUT.md is 0.9.1. The 1.0.0 house rule (regenerate all four plus README and GitHub details) is not done yet.	auditor (docs read)	OPEN

ID	Sev	Component	Finding	Evidence	Status
PGM-325	INFO	Migrations	All five historic schemas (built by the code of v0.1.0, v0.2.0, v0.4.2, v0.6.0 and v0.9.0, with books, reads, shelves, quotes, a locked book and a trashed book) open in the current app with every row kept, user_version 6, integrity_check ok, foreign_key_check empty, and accept every 0.12 and 0.13 write.	script pgm300_migration_test.dart	VERIFIED
PGM-326	INFO	Release integrity	Published v0.13.0 APKs verify (v2 scheme), are signed by the expected certificate (SHA-1 390459ad...), their SHA-256 matches the local build and the GitHub digest, no secrets or personal data in the built APK, allowBackup=false, no storage permissions, only the expected library components exported. CI is green on the tagged commit b1bbf51.	script pgm220_release_verify.sh, pgm200_apk_scan.py	VERIFIED
PGM-327	INFO	Layouts and large text	Side rail at 600 dp and two panes at 840 dp render and work (a tapped book fills the right pane). At font scale 2.0 the Library, Stats and a book page show no clipping or overflow.	auditor (evidence_1.0/f11_pane_book.png, g2_stats_f2.png, g3_book_f2.png)	VERIFIED

Audit status - Pagemark 0.7.0

- Repo: C:\Project Folder\Pagemark, branch main, audited commit `045e8147c28780fd03dd0f714cce9d0225071f13` (tag v0.7.0), working tree clean at start.
- OS: Windows 11 Pro; Flutter 3.47 at C:\dev\flutter; JDK 25 (needs `-Djdk.net.unixdomain.tmpdir=C:/tmpj`); Android emulator x86_64.
- Suite from fresh clone: 193 pass + 1 skip, twice (33 s, 20 s). `flutter analyze` clean. build_runner output matches committed code.
- Real user data to avoid: none touched. Emulator used throughout; scratch data under the session scratchpad.
- Mode: full, mobile-leaning. Prefix PGM. Mine PGM-001..099, data agent 100..199, security agent 200..299.

Phase log

Phase	State
0 Baseline	done
1 Feature inventory	folded into FEATURE_MATRIX notes in the agents' files; no separate matrix written
2 Suite audit	done (counts above); per-module coverage not measured
3 Smoke	done on release x86_64 (first launch, 5k restore, cold starts)
4 GUI	partial: font 2.0, landscape attempt, library/stats/settings seen; full activation sweep NOT RUN
5 Data safety	done by script (findings_part_data.md)
6 Engine	done by script
7 Hostile input	done by script
8 Security	done (SECURITY_AUDIT.md)
9 Performance	done on emulator (PERFORMANCE_BASELINE.md)
10 Packaging	done (RELEASE_ENGINEERING_AUDIT.md)
11 Docs truth	done (DOCS_TRUTH.md)
12 Compat	static only (COMPAT_MATRIX.md)
13 Report	RELEASE_READINESS.md, MANUAL_TEST_PLAN.md, FINDINGS.md written

Not written

DATA_SAFETY_MATRIX.md, ENGINE_AUDIT.md, HOSTILE_INPUT.md, FEATURE_MATRIX.md, GUI_MATRIX.md, NAVIGATION_MATRIX.md, TEST_COVERAGE.md: the data agent could not write report files and its results live in findings_part_data.md and its scripts; the GUI/feature matrices were not produced.

NOT RUN

Everything in MANUAL_TEST_PLAN.md: real device, fingerprint, Drive, WorkManager/Doze, updater install, TalkBack, tablets, iOS.

1.0.0 gate audit (2026-10-14)

- Audited: Pagemark 0.13.0, commit `b1bbf517a9152ba2b70281c03ec8b07897b23a73` (tag v0.13.0), working tree clean, CI green. New findings PGM-300 to PGM-327.
- Baseline from a fresh clone of HEAD: build_runner output identical to the committed code, `flutter analyze` clean, suite 289 pass + 1 skip, twice (33 s, 22 s).

- Run on: Windows 11, Flutter 3.47, Android emulator Pixel_10_Pro_XL_test (x86_64) with the release sideload build of 0.13.0; wm size/density and font scale restored afterwards. No real user data touched.

Phase	State
0 Baseline	done (above)
2 Suite	counts and flakiness done; per-module coverage not measured; test files named in TEST_COVERAGE.md
3 Smoke	emulator: first launch, welcome skip, empty library, search + add (live network), restart at font 2.0
4 GUI	partial. Seen: welcome, empty library, tablet rail, two-pane with a book, Stats on a tablet, font 2.0 on Library/Stats/book. Full activation sweep and every screen at every size NOT RUN
5 Data safety	migrations from every schema 1 to 5 done by script (PGM-325). Restore/backup paths unchanged since the 0.7.0 audit and covered by its scripts and the suite; folder backup (SAF) NOT RUN on a real provider
6 Engine	timer state tested (PGM-320); streak, year summary, queue order, suggestions covered by v0120/v0130 tests, reviewed
7 Hostile input	Google Books and editions parsers fuzzed, 5,000 + 400 random shapes (PGM-303)
8 Security	published asset verification, APK secret scan, manifest permissions and exported components, network host inventory (promise_test)
9 Performance	NOT RUN this round (0.7.0 baseline stands; new Stats calendar and two-pane not profiled)
10 Packaging	release assets verified; 16 KB alignment checked
11 Docs	README and release-package read against 0.13.0 (PGM-324)
12 Compat	tablet/landscape seen on the emulator; foldables, multi-window, other OEMs NOT RUN
13 Report	RELEASE_READINESS.md, MANUAL_TEST_PLAN.md updated

Scripts added: pgm300_migration_test.dart, pgm310_lookup_fuzz_test.dart, pgm320_stuck_timer_test.dart. Evidence screenshots: docs/release-audit/evidence_1.0/.

NOT RUN this round

Everything in MANUAL_TEST_PLAN.md, plus: reading timer on a running device (only its widget logic was tested), share picture and PDF share sheets, Scan many books with a real camera, folder backup to a real cloud provider, notification delivery (loan reminders), TalkBack, performance of the new screens.

Manual test plan - what a human must still do (on a real phone)

Ordered by risk. Nothing here was run by the audit.

- ☐ **Restore twice, recover the first state** (PGM-100). Restore a backup, restore a second one within a minute, look for any way back. Pass: the original library is recoverable.
- ☐ **FLAG_SECURE and recents** (PGM-204). Open the hidden Locked tab, press Home, open recents. Pass: the thumbnail is blank.
- ☐ **Fingerprint unlock** on a real device: unlock, cancel, wrong finger, fingerprint added after setup.
- ☐ **Drive sign-in and scheduled backup**: sign in, run now, wait one scheduled cycle, restore from the Drive file. Pass: file appears, size matches, restore works.
- ☐ **Passphrase change** (PGM-102): change the backup passphrase, run backup, check a new file appears and decrypts.
- ☐ **Updater install**: from 0.6.0 install 0.7.0 through Settings > Updates. Pass: installs over the top, data intact, same signing certificate.
- ☐ **Battery managers / Doze**: on a phone with an aggressive battery manager (Samsung, Xiaomi), confirm scheduled backups still run after two days.
- ☐ **Notifications**: deny and re-grant the permission; backup-failure notification shows.
- ☐ **Storage full**: fill storage, try an export and a restore. Pass: clear error, library untouched.
- ☐ **Shared exports left behind** (PGM-203): export CSV, share it, inspect `cache/share_plus` (needs a debug build or adb on a rooted device).
- ☐ **Landscape and tablet/foldable** (PGM-004, 254): rotate every main screen; check split-screen.
- ☐ **TalkBack**: add a book, rate it, open Settings with TalkBack on; icon buttons have names.
- ☐ **Edge-to-edge and predictive back** (PGM-253) on Android 14/15/16.
- ☐ **Large font / display size** on a phone (PGM-001): font 2.0 and largest display size on Library and Book pages.
- ☐ **Offline use**: airplane mode, add a book by hand, open covers, run lookup. Pass: no crash, clear message.
- ☐ **Real timezone change** (PGM-128): finish a book, change timezone, check the date.
- ☐ **iOS**: not built yet; everything above is Android only.

Added for the 1.0.0 gate (0.13.0)

- ☐ **Reading timer**: start on a book, lock the phone for 2 minutes, stop, enter a page. Pass: the minutes and page are saved and the day lights up in Stats. Then start a timer and finish the book: pass only once PGM-320 is fixed (other books can still stop the timer).
- ☐ **Share picture and PDF report**: Stats, Year in books, Share picture and Report (PDF) into Messages or Drive. Pass: the picture and PDF open, show no locked book.
- ☐ **Lending reminder**: lend a book with a reminder for the next day (set the phone clock forward). Pass: a notification at 10:00 that names neither book nor person; Got it back cancels it.
- ☐ **Scan many books**: scan 5 real books including one you own. Pass: one click each, duplicates skipped, a not-found one listed. Try in the Locked library: the internet warning appears once.
- ☐ **Refresh details and edition picker** on a book you edited by hand. Pass: your edits are not ticked; choosing an edition changes only the cover, publisher, year, pages and ISBN.
- ☐ **Google Books switch**: turn it off, search; turn on, search. Pass: results differ only in coverage; nothing breaks offline.
- ☐ **Folder backup** to a Google Drive or OneDrive folder through Android's picker; wait one scheduled run; restore on a second phone.

- ☐ **Tablet and landscape on a real device or foldable**: rail, two panes, rotate with a book open, split-screen.
- ☐ **TalkBack** through: add a book, rate with swipe, calendar days, Read next reorder, Lend.
- ☐ **Updater**: install 0.13.0 over 0.12.0 from Settings > Updates. Pass: data intact, same signature.